



Advanced Digital Manufacturing Solutions

Magestic Responsible AI Policy

Trusted AI principles, the managed-boundary data governance model, acceptable use, AI feature transparency, intellectual-property protection, and contract-specific compliance schedules

Field	Detail
Document	Magestic Technologies Responsible AI Policy
Version	1.0: For All Employees
Policy Reviewed	Q3 2026
Applies to	All employees, contractors, and AI used internally or shipped in products
Status	Confidential: internal use only
Review cadence	Quarterly, or upon material change in law, tooling, customer contracts, or products

Executive Summary

Why this policy exists. Magestic Technologies develops advanced digital manufacturing software that our customers run in production, and it is preparing to bring third-party AI tools into daily work under this policy. Adopting AI creates real value and real exposure: to data leakage, to claims that AI output infringes another party's intellectual property, and to the erosion of our own proprietary IP. This policy lets Magestic capture AI's value at full speed while protecting the company, its customers, and its trade secrets.

Our model. We follow the pattern the most trusted enterprise software vendors operate publicly: commit to five Trusted AI principles; govern AI through a certified-shape management system; bring best-in-class third-party models to the data inside a company-managed boundary rather than sending data out to third-party applications; block model providers from training on customer content through hosting choices and contractual and technical controls; disclose every customer-facing AI feature through a transparency card; and secure, in our own contracts, the rights that make responsible data use possible.

The core data rule. Customer-identifiable material is anonymized or replaced with synthetic equivalents before AI contact as the default. Raw customer content may be processed by AI only inside a Magestic-managed boundary, under no-training terms, with a named approval, and only where the governing contract permits. De-identified and aggregated data may be used to improve our offerings where contracts allow, and never before a documented, counsel-reviewed clearance for that engagement exists in the Data Use Register (Section 4.3). Where a specific contract is stricter, its compliance schedule governs that engagement, up to and including full exclusion of that customer's data from every AI system in any form.

What every employee must do. Use only approved AI tools on company-provisioned, company-paid accounts with no-training terms verified, and never a personal account of any kind; anonymize customer-identifiable material before any AI contact, and confirm a Data Use Register clearance for the engagement first; never place export-controlled technical data into any AI tool in any form; keep a named human accountable for every AI-assisted output, with an engineer reviewing, testing, and merging every AI-drafted change; and scan AI-assisted code for security flaws and license contamination before merge.

Two directions of IP risk. (1) We protect our own crown-jewel IP (the nesting engine, the genetic-algorithm and no-fit-polygon methods) through trade-secret discipline, patents where novel, copyright, human authorship of shipped code, contracts, and access control. (2) We protect against infringing others' IP through vendors that indemnify, guardrails that keep the indemnities valid, provenance and contamination scanning, and clean training data.

Accountability. The Director of AI, supported by the cross-functional AI working group, owns this policy, approves tools and use cases, maintains the AI inventory and exception log, and reports to executive leadership. The policy is reviewed at least quarterly.

1. Purpose and Ethos

Magestic Technologies develops manufacturing software, including proprietary nesting and optimization engines, for customers in aerospace, energy, transportation, automotive, and general fabrication. This policy establishes how Magestic develops, deploys, and uses artificial intelligence so that we capture its value while protecting our customers, our people, and our intellectual property.

The objective of Magestic's AI governance is to **deliver value and minimize risk to privacy and intellectual property**. We hold ourselves to responsible, ethical, and secure practices across the entire AI lifecycle: how we acquire and manage data, how we train, test, ship, and monitor AI features, and how our own people use AI tools in their daily work.

The framework is built on established, auditable standards (the NIST AI Risk Management Framework and ISO/IEC 42001) and on the governance practices that leading design and manufacturing software vendors publish: stated principles, per-feature transparency disclosures, and managed use of third-party frontier models. Where Magestic's rules are stricter than industry practice, it is because our contracts, size, or risk profile require it, and those differences are stated explicitly rather than left implicit.

2. Scope and Order of Precedence

This policy applies to:

- **All personnel:** employees, contractors, interns, and temporary staff acting on Magestic's behalf.
- **All AI use:** third-party AI tools used internally (coding assistants, chat assistants, document, meeting, and image tools) and AI components developed into or embedded within Magestic products.
- **All data:** Magestic confidential information, source code and algorithms, customer and partner data, personal data, and export-controlled technical data processed with the assistance of AI.

"AI" includes machine learning, generative AI, large language models, agentic coding tools, genetic and other optimization algorithms, and any system that produces outputs, recommendations, or decisions with limited human intervention. For clarity: the proprietary algorithms Magestic itself develops and ships inside its products, including its genetic-algorithm and geometric-optimization nesting engines, are Magestic product technology. This policy governs the use of third-party AI tools and services; it does not restrict Magestic's own in-house algorithms, which remain governed by normal product engineering and the IP protections of Section 11.

Order of precedence. (1) Applicable law, including export control, always governs. (2) An executed customer contract governs the data of that engagement where it is stricter than this policy; such contracts are implemented as compliance schedules (Section 13) so their obligations are scoped to the engagements they bind rather than generalized across the company. (3) This policy governs everything else.

Current scope of authorized AI use. This policy authorizes, on company-provisioned seats: internal business productivity (research, drafting, documents, analysis, meeting support, questionnaire and proposal work); software development assistance, including writing code for Magestic products, always with a human in the loop (Section 7.3); QA, QC, and testing analysis; and prototyping, modeling, and proof-of-concept work on internal data and on cleared, verifiably de-identified customer data under the Section 4 treatments. Two things are expressly not authorized at this time: third-party AI embedded in, shipped with, or called at runtime by any Magestic product (Section 10), and any AI tool holding autonomous write access to a repository or production system, or AI-drafted code reaching production without human review (Section 9). Either would require an explicit leadership decision and a revision of this policy first.

3. Guiding Principles for Trusted AI

Every AI decision at Magestic (what we build, what tools we adopt, and how we use them) is measured against five principles:

Principle	What it means at Magestic
Responsible	We hold high standards for how we acquire, license, and manage data, and for training and delivering AI that is fair, safe, and fit for its stated purpose. We do not pursue AI uses that we cannot operate responsibly or that our contracts prohibit.
Transparent	We are clear, internally and with customers, about where AI is used, what it does, what data it relies on, and its known limitations. Any customer-facing third-party AI capability, if ever approved, would ship with an AI Feature Disclosure (Section 10.2); none exists today.
Accountable	A named human is responsible for every AI-assisted output and decision. We respect customer choices and align to applicable laws, contracts, and regulations.
Reliable	We engineer AI for accuracy, validity, and consistency, and we test and monitor it across its lifecycle rather than assuming it works.
Safe & Secure	We protect data, privacy, and intellectual property, and we design AI to produce safe outcomes, guarding against misuse, leakage, bias, prompt injection, and unsafe results through configuration-enforced controls, not trust.

4. The Managed-Boundary Data Governance Model

This is the central operating model of the policy. The governing insight: the question is not whether third-party models touch data; it is who controls the boundary the processing happens inside, and what the provider is permitted to do with what it sees.

4.1 The boundary rule

Third-party AI models may process Magestic data, and customer-derived data where Section 4.2 and the contract schedules permit, only inside a Magestic-managed boundary. A managed boundary means one of:

- **In-tenancy hosting (defined, not currently deployed):** frontier models served inside Magestic's own cloud tenancy with region pinning and customer-managed keys, so content never persists on the model provider's systems. Magestic has not stood up this boundary; it is documented as the required path should a future, leadership-approved need arise. Until it exists, raw customer content has no AI route at all.
- **Blocked commercial endpoints:** company-managed business-tier plans (individual paid seats and team-tier plans) and commercial API endpoints operating under terms that exclude customer content from model training by default, with retention set to the shortest available configuration, feedback and training-sharing features disabled org-wide, and data processing agreements in place. Zero-data-retention arrangements are an enterprise or negotiated API feature that Magestic does not currently hold; see Plan-Tier Posture in Section 6.

The no-public-training commitment. Our standing commitment: data processed through Magestic-managed AI infrastructure is never used by external model providers to train their public models. We maintain the paperwork (tier confirmations, DPAs, and zero-data-retention terms where held) and the configurations (feedback disabled, retention minimums) that make this claim auditable rather than merely asserted.

How this commitment holds at every plan tier. This commitment does not depend on enterprise plans. On business and team-tier workspaces, exclusion of workspace content from model training is the default of the commercial terms themselves, the same default the enterprise tiers carry; it is a property of being on business terms at all, not a feature purchased at a higher tier. What varies by tier is how the claim is evidenced and which exceptions must be actively managed:

- **Paperwork at the current tier:** the tier confirmation showing each workspace is on a business plan (never consumer), the executed data processing agreement (available self-serve at business tier), and the vendor's subprocessor list on file. Zero-data-retention terms are an enterprise or negotiated API arrangement; where Magestic does not hold them, none are claimed (Section 6, Plan-Tier Posture).
- **The configuration that carries the weight:** feedback and training-sharing features disabled org-wide and kept disabled. Feedback is the exception that can swallow the rule: a single thumbs-up or thumbs-down can submit an entire conversation into the vendor's training pipeline with multi-year retention. Disabling it org-wide on day one, and verifying it stays disabled at each quarterly review, is what keeps this commitment true on team-tier plans.
- **The exception no tier removes:** vendor safety and abuse-detection systems can retain flagged content beyond normal windows at every tier, and this cannot be disabled. Retention promises are

therefore probabilistic, not absolute, which is one reason genuinely sensitive material stays inside managed boundaries regardless of contract terms.

- **Evidence by tier:** enterprise tiers evidence this commitment with audit logs and compliance-API exports; business and team tiers evidence it with the executed DPA, workspace configuration records, and training logs. That is a lighter evidence layer, not a lighter commitment, and it is the current posture disclosed in Section 6.

What sits outside every boundary. Consumer and free-tier AI applications, any account Magestic does not own and administer (including personal subscriptions at any price, whether or not expensed), and any tool not on the approved list (Appendix A) are outside the managed boundary. Customer data, in any form including anonymized, does not go there. That flow (an employee submitting customer material to an external AI application under personal terms) is not authorized by any reputable vendor's published policy, and it is prohibited here.

4.2 Customer content treatments

Customer-supplied material (CAD/DXF/DWG/STEP files, part geometry, PLM exports, order data, machine and material parameters, support tickets, and personal data) is handled with a defined treatment, checked in this order:

Step	Treatment	Rule
1	Clearance check (mandatory)	Confirm a current clearance for the engagement in the Data Use Register under the protocol in Section 4.3. No clearance means no processing, in any form, including anonymized. Schedule-restricted engagements (Section 13) are permanently marked prohibited.
2	Anonymize-first (default)	Customer-identifiable material is de-identified or replaced with synthetic equivalents before any AI contact. De-identification must be verifiably complete under the adequacy standard in Section 4.3, step 3: names, identifiers, metadata, and traceable geometry removed or substituted.
3	De-identified and aggregated use	De-identified or aggregated customer data may be used inside managed boundaries where the clearance permits, including for QA, prototyping, modeling, and proof-of-concept work, consistent with the rights framework in Section 12 and the choice framework in Section 10.2.
4	Raw customer content	Raw, identifiable customer content may be processed by AI only inside a managed boundary, under no-training terms, with approval by the Director of AI, a named use-case owner, and customer consent where the contract or the choice framework requires it. At Magestic's current plan tier, a managed boundary for raw customer content means in-tenancy hosting (Section 4.1), which is not currently deployed; raw customer content therefore has no AI route at present. Never through consumer tools, and never through extended-retention model classes (Section 8).

4.3 The Customer-Data Clearance Protocol

Anonymization is never, by itself, authorization. Before any customer-derived data (raw, pseudonymized, anonymized, de-identified, aggregated, or synthetic-derived) is submitted to any third-party AI service, a documented clearance for that specific engagement must exist in the Data Use

Register. The default answer, when no clearance is on file, is no. This protocol exists because the two failure modes it prevents are exactly the ones that end enterprise relationships: a contract that quietly bars de-identified use (some executed customer agreements do, expressly), and data that was never as anonymous as it looked.

Step 1: Contract and agreement review (tiered). For each customer engagement, the Director of AI reviews every governing document against the checklist below: the master agreement, SOWs and purchase orders (which can carry terms stricter than the master), NDAs signed at any point in the relationship, data-processing addenda, side letters, and amendments. Outside counsel is engaged on defined escalation triggers: restrictive or ambiguous data-use language, any bar or possible bar on aggregated or de-identified use, regulated or critical-infrastructure customers, candidates for a compliance schedule, or anything the Director of AI cannot clear with confidence. The review enumerates, clause by clause: confidentiality provisions and whether their carve-outs cover AI processors; data-use and exploitation restrictions, specifically including any bar on aggregated or de-identified use; residency and location requirements; subprocessor authorization and flow-down obligations; audit and inspection rights; return, destruction, and retention clocks; incident-notice obligations; and IP or derivative-works provisions that could reach model improvements. Ambiguous language is treated as prohibitive until escalated counsel review clears it or the customer consents in writing. Silence is assessed by counsel against the relationship and applicable law, not assumed to be permission.

Step 2: Regulatory overlay. Contractual permission is necessary but not sufficient; each clearance also documents the regulatory position. Under GDPR and UK GDPR, pseudonymized data is still personal data, and only data that fails the "means reasonably likely to be used" re-identification test of Recital 26 is anonymous; where personal data remains, the Article 28 processor chain, Standard Contractual Clauses with a transfer impact assessment for third-country endpoints, and a DPIA where processing is likely high-risk all apply. Under CCPA/CPRA, de-identified data requires reasonable technical safeguards, a public commitment not to re-identify, and contractual flow-down of both. Equivalent regimes (LGPD, PIPEDA, APPI, Singapore PDPA, the Australian Privacy Act) follow the same processor-contract plus transfer-mechanism pattern. EU AI Act deployer and transparency duties apply to the AI use itself. Sector overlays are checked where the customer operates in one: utility and energy customers may carry critical-infrastructure obligations (for example NERC CIP-011 information-protection requirements) that reach vendor handling of system data. And export control is non-negotiable: anonymization never cures an ITAR/EAR problem; Tier 4 material stays out of AI entirely (Section 5.1).

Step 3: Re-identification risk assessment (anonymization adequacy). De-identification is a technical claim that must be tested, not a label. Each cleared anonymization method is documented and assessed against the motivated-intruder standard: could a party with access to public information and reasonable means re-identify the customer or its program? Manufacturing data deserves specific skepticism, because geometry is identifying: a distinctive part profile, tolerance scheme, or process parameter set can identify a customer or even a defense program with no name attached, and CAD interchange formats (DXF, DWG, STEP) carry metadata (title blocks, layer names, block attributes, external references, file paths, author fields) that survives casual scrubbing. The standard treatment strips metadata mechanically, replaces identifying geometry with synthetic or generalized equivalents, and has a second person sample-check outputs before the method is approved. Aggregation thresholds are set so no single customer's data is recoverable from any aggregate.

Step 4: Vendor-terms check. The receiving AI service must be inside a managed boundary (Section 4.1): no-training terms executed, retention minimized, feedback sharing disabled, subprocessor list reviewed, and residency consistent with any location requirement found in step 1.

Step 5: Record, decide, and re-review. The clearance is recorded in the Data Use Register: engagement, documents reviewed, clause citations, regulatory position, approved anonymization method, permitted treatments, the Director of AI as named approver, counsel sign-off where an escalation trigger applied, and date. Every clearance carries one of three outcomes. Green: contract and regulation permit; Section 4.2 treatments apply as cleared. Yellow: ambiguity or partial permission; counsel review or written customer consent required before any processing. Red: express restriction; the engagement gets a compliance schedule (Section 13) and its data is excluded. Clearances are re-reviewed at contract renewal or amendment, on any material vendor-terms change, and at the quarterly policy review. The Register is the audit artifact shown to customers and assessors.

This protocol is the operational core of the policy: Magestic can state to any customer or auditor that customer data is protected in its AI pipeline because rights, safeguards, and disclosures are established per engagement before processing, not defended after it. The Register is the standing evidence behind that statement, scaled to Magestic's size. The tiered review also implements what ISO/IEC 42001 and the NIST AI RMF actually require here: a defined, accountable role operating a documented control consistently, with competence matched to the difficulty of the call; neither framework requires counsel involvement, and escalation reserves it for the cases where it earns its cost.

4.4 Isolation and privacy filtering

Customer data used in any AI workflow is logically isolated by customer, so no processing mixes one customer's content with another's; privacy filtering screens prompts and pipelines for personal data before submission; and access follows least privilege with logging. Support-ticket content remains isolated per customer, encrypted, used only to resolve the customer's issue, and removed on resolution.

5. Data Classification: Four Tiers

Classify information before using it with any AI tool. Every document, repository, and dataset gets a tier; when in doubt, treat material as the higher tier until someone with authority says otherwise.

Tier	What's in it	AI tool treatment
T1 · Public	Published docs, marketing copy, open-source code	Any approved tool; no restrictions.
T2 · Internal	Internal docs, meeting notes, general business material; Magestic-owned source code	Business material: approved commercial accounts only (no-training verified, feedback sharing disabled); never personal accounts. Source code: approved coding tools may read, analyze, and draft it under the Section 9 harness; every change that ships is reviewed, tested, and merged by a Magestic engineer, and no AI tool holds autonomous write, push, or deploy access. Crown-jewel algorithm internals additionally follow Section 11.1 and never touch extended-

Tier	What's in it	AI tool treatment
		retention model classes.
T3 · Customer-confidential	Customer names tied to technical detail, part geometry, CAD/PLM exports, CRM records, order data, quotes, support tickets	Section 4.2 treatments: contract check, then anonymize-first; de-identified use inside managed boundaries where contracts permit; raw content only inside a managed boundary with approval and required consent. Schedule-restricted engagements are excluded entirely.
T4 · Export-controlled	Any technical data plausibly subject to ITAR/EAR, likely within defense-adjacent engagements	Absolute exclusion from all AI tools, with no anonymization exception, pending export-control counsel review. This tier is set by law, not contract.

5.1 Export control: why Tier 4 stays absolute

ITAR technical data covers information required for the design, production, testing, or modification of defense articles, a definition that can reach part geometry and manufacturing process data for defense customers. Sending controlled data to a commercial AI service can itself constitute an unauthorized export, including a deemed export if foreign nationals at the vendor can access processing systems, and prompts often leave no audit trail on our side. These regimes are self-governed and the penalties (seven-figure civil fines per violation, criminal exposure for willful violations, debarment) fall on Magestic directly. No customer contract can relax this tier, and nothing else in this policy does either.

6. Governance and Accountability

AI management system (ISO/IEC 42001 alignment). Magestic operates its AI program in the shape of the ISO/IEC 42001 standard: a documented AI management system covering risk assessment before any feature or tool deployment, per-use-case lifecycle oversight from design to retirement, fairness and bias testing where AI affects outcomes, defined human-in-the-loop checkpoints, and continuous monitoring with periodic review. Certification is a later, separate decision; operating in certifiable shape is the standing commitment, and it is what enterprise procurement questionnaires increasingly ask for.

The Director of AI. The Director of AI owns this policy and is responsible for changes to it, prepared and revised in conjunction with the AI working group. The Director of AI maintains the Approved AI Tool Register, the AI-system inventory, and the AI Feature Disclosure library, and is the approver for high-risk AI uses, including any AI processing of raw customer content. Policy changes are signed at C-suite level.

AI working group. The cross-functional AI meeting (engineering, product, information security, legal, and a business owner) is the governance body. It approves new tools, data classes, and autonomy levels; reviews incidents, near-misses, and the exception log; classifies risk (Appendix C); and re-certifies the approved-tool list quarterly. It meets at least monthly, more frequently during ramp-up, and escalates material risks to executive leadership.

Use-case owners and the exception rule. Every AI workflow has a named owner who answers for its behavior. Anything not explicitly permitted is asked about in the AI working group and the answer is recorded. An exception granted twice becomes a policy line; a rule that never fires gets relaxed at quarterly review.

Self-hosting posture. Per leadership decision (July 2026), Magestic does not self-host or internally operate models; the managed-boundary options in Section 4.1 (in-tenancy cloud and blocked enterprise endpoints) are the affirmed architecture. Reopening self-hosting requires leadership sign-off.

Plan-Tier Posture and Policy Evolution

Current posture. Magestic currently uses third-party AI through company-provisioned, team-tier business workspaces, with seat and usage tiers assigned per role (standard seats, high-usage premium seats for power users, and developer coding-agent tooling under the Section 9 harness), plus commercial API access under spend limits. These tiers carry the protections this policy relies on: customer content excluded from model training by default, executed data processing agreements, admin controls, and feedback sharing disabled. They do not carry certain enterprise-only capabilities, and this policy is written so that no rule and no external commitment depends on a capability the current tier cannot deliver.

Initial deployment. Adoption starts deliberately small: a pilot fleet of team-tier seats across two approved AI platforms, mixing standard and premium seats to match the roles piloting them, with monthly billing until the pilot proves which seats stick. The specific platforms, seat counts, assignments, and configurations live in the Approved AI Tool Register, so the fleet can grow or rebalance without amending this policy. Every seat is opened under the workspace DPA, with feedback and training-sharing disabled and the configuration recorded before first use. The initial scope is business productivity, development assistance with a mandatory human in the loop, QA and testing analysis, and prototyping under the Section 9 harness: third-party AI runs inside no Magestic product, and no AI tool holds autonomous write, push, or deploy access to any repository or production system. The legal rationale for this posture over individual subscriptions is set out in Section 7.1.

What the current tier means in practice:

- **Retention:** workspaces run on the shortest available retention settings with deleted-conversation purge on the vendors' published cycles. Magestic does not represent zero-data-retention to anyone, because ZDR is an enterprise or negotiated API arrangement we do not currently hold.
- **Residency:** business-tier processing occurs on vendor-managed infrastructure in the vendors' regions. Magestic makes no data-residency representations for these tools; where a customer requires residency, the in-tenancy route (Section 4.1) is the only path.
- **Evidence:** audit-log and compliance-API exports are enterprise features. At the current tier, Magestic's audit evidence is its policy, workspace configuration records, vendor terms on file, gateway and telemetry logs where deployed, and training records.
- **Raw customer content:** because ZDR endpoints are unavailable at this tier, the managed boundary for raw customer content is in-tenancy hosting only (Section 4.2, step 4).

Policy evolution on upgrade. This policy will change if Magestic upgrades its third-party AI usage to enterprise plans on its approved AI platforms, or executes equivalent negotiated API terms. An upgrade unlocks controls this policy currently treats as unavailable: custom retention windows, executed zero-data-retention routing for designated workloads, compliance-API audit-log exports as customer-facing evidence, expanded SSO/SCIM identity management, and, where offered, residency or regional-inference options. Upon any such upgrade, the Director of AI will bring a revision through the AI working group before anyone relies on the new capabilities, updating at minimum: the managed-boundary definitions (Section 4.1), the raw-customer-content route (Section 4.2), retention and evidence commitments (this section), model governance (Section 8), the audit-evidence posture offered to customers, and any compliance schedule whose negotiations assumed the earlier tier. Until that revision is issued, the current-tier rules remain in force regardless of what the new plan technically permits.

7. Acceptable Use of AI Tools by Personnel

7.1 Company accounts only: personal accounts are prohibited

All AI work for Magestic runs on accounts that Magestic provisions, owns, administers, and pays for, inside company-controlled workspaces. This is the first rule of the policy in daily practice, and it has no exceptions:

- **No personal accounts, in any form, for any Magestic work.** No personal, consumer, free, trial, or individually-subscribed AI account may be used for any Magestic work, any company data, or any customer data, at any data tier, on any device. This includes paid consumer power tiers: paying for, or expensing and reimbursing, a personal subscription does not make it a company account. Consumer terms travel with the account type, not the payer: user-controlled training settings, no organizational data processing agreement, no admin controls, and no centralized off-boarding remain exactly as they were no matter whose card is on file.
- **What counts as a company account.** An account is a company account if it is provisioned by Magestic inside a company workspace, operates under commercial or business terms with an executed data processing agreement, is administered centrally (SSO and MFA where the tier supports it, no shared logins), and is billed directly to Magestic.

Why business-tier team seats, and not individual subscriptions: the legal difference. The choice of team plans over individual consumer subscriptions is a legal decision, not a convenience. Business-tier workspace seats deliver protections that no individual subscription carries, whoever pays for it:

- **Contractual no-training terms.** On business plans, exclusion of workspace content from model training is a term of the commercial agreement, enforceable against the vendor. On individual consumer accounts it is a user-controlled setting that any user can flip and no contract guarantees.
- **An executed data processing agreement.** Business tiers offer a signable DPA carrying GDPR Article 28 processor obligations, Standard Contractual Clauses for international transfers, breach-notification duties, and a published subprocessor list. Consumer accounts have none of this, which means personal-account use of company data is not merely risky but undocumentable to any regulator, customer, or auditor.
- **Commercial terms of service.** Business agreements address confidentiality of customer content, ownership of inputs and outputs, and, at several vendors, indemnification protections that consumer terms do not offer. Magestic's rights in AI-assisted work product are cleanest when the account itself belongs to the company under commercial terms.
- **Enforceable configuration.** Workspace admin controls let Magestic disable feedback and training-sharing org-wide and keep it disabled, turning this policy's commitments (Section 4.1) from promises into settings. On individual subscriptions the same commitments depend on each user's discipline and cannot be locked.
- **Identity and lifecycle control.** SSO and domain capture where supported, centralized provisioning, and instant deprovisioning: when someone leaves, their AI access ends with their email. Company work product, prompts, and history remain in a Magestic-owned workspace rather than departing inside a personal account, which also preserves records for discovery, audit, and IP purposes.
- **Compliance evidence that transfers.** Vendor certifications (SOC 2, ISO 27001 and related) and trust documentation apply to their commercial products, not their consumer accounts. Only business-tier usage lets Magestic cite that assurance stack in customer questionnaires, contract representations, and its own trust materials.
- **Insurance and warranty posture.** Demonstrable, centrally enforced controls are what cyber and technology-E&O underwriters and customer security teams credit. A fleet of individual subscriptions provides nothing an underwriter or auditor can verify.
- **Seat types are matched to roles, not one-size-fits-all.** Company workspaces may carry multiple seat and usage tiers: standard seats for general productivity, high-usage premium seats for power users whose daily work justifies the capacity, developer coding-agent tooling under the Section 9 harness, and metered API access with per-user and organization-wide spend limits. The Director of AI assigns each team member's tooling in the Approved AI Tool Register based on role and usage profile, and the AI working group reviews the assignments. Changing a person's seat tier within an approved plan is a Register update, not a policy amendment, so heavy users can be provisioned the capacity they need without anyone routing around the policy.
- **Transition and rogue use.** When this policy takes effect, all use of personal accounts for Magestic work stops and moves to company accounts; reimbursement requests for personal AI subscriptions are not approved. Use of a personal account for Magestic work after the effective date is a reportable incident (Section 15) and an enforcement matter, whatever the intent. The company pairs this prohibition with an obligation of its own: Magestic provisions and pays for AI tooling adequate to each role, so no one has a capacity reason to go around the policy.

- **No-training terms verified in writing.** Every approved vendor's tier, retention window, training opt-out, ZDR availability, and subprocessor list is confirmed in writing and filed with this policy.
- **Feedback and training-sharing features disabled org-wide.** This keeps the no-public-training commitment (Section 4.1) true, and it is additionally a contractual requirement for schedule-restricted engagements.
- **SSO plus MFA, centralized seat management, no shared logins, quarterly seat review.** Offboarding revokes AI access the way it revokes email.

7.2 Prompts and data

Apply the four tiers (Section 5) and the treatments in Section 4.2. T1 freely on approved tools; T2 on approved no-training accounts; T3 through the treatment ladder (contract check, anonymize-first, managed boundary for anything more); T4 never. Secrets (API keys, credentials, .env files) never appear in prompts; deny rules exclude credential paths from being read, and any secret that reaches a prompt is treated as exposed and rotated the same day.

7.3 Human-in-the-loop: flag, don't fix

AI assists; people remain accountable. Developers may use approved coding tools to analyze, draft, and write code, including code for Magestic products, on one absolute condition: a human is always in the loop. Every AI-drafted change is reviewed, understood, and tested by a Magestic engineer before it is committed, and the engineer who merges it owns it exactly as if they had written it. AI-generated output is a draft, not a source of truth; no developer ships code they cannot explain. This rule is also the IP-optimal pattern, because meaningful human authorship and review keep copyright with Magestic (Section 11). AI-generated output is a draft, not a source of truth: a qualified employee must review and validate it before it ships to a customer, enters a production codebase, or informs an engineering or business decision. This is also the IP-optimal pattern, because human authorship keeps copyright with Magestic (Section 11).

7.4 Meetings and transcription

AI transcription is permitted for internal meetings with participant awareness, on approved tools. Customer calls require the customer's consent; transcripts of customer calls are T3 by definition. Where a tenant-bound option exists, prefer it for customer-facing calls. Transcripts are discoverable business records regardless of tool.

7.5 Prohibited uses

- Performing any Magestic work through a personal AI account of any kind (free, consumer, or paid), including expensed or reimbursed personal subscriptions.
- Submitting customer data in any form, including anonymized, to consumer-grade or unapproved AI tools, or identifiable customer data to any tool outside a managed boundary without the approvals in Section 4.2.
- Placing Tier 4 export-controlled data into any AI tool in any form.
- Using AI-generated code without checking it for security flaws and third-party license obligations before merge.
- Merging, shipping, or deploying AI-drafted code without human review and testing, or granting any AI tool autonomous write, push, or deploy access to a Magestic repository or production system. AI-

assisted development is permitted under the Section 9 harness with a human in the loop on every change.

- Letting an AI agent push, deploy, or modify production systems, or granting an agent a production database connection (agents get read-only accounts on development instances with schema plus synthetic or anonymized data).
- Presenting AI output as human-authored where authorship matters (legal attestations, certifications).
- Installing AI tools outside approved access paths, including desktop installers that require weakening machine-wide security controls on machines that hold customer data.
- Using AI in ways that violate a customer contract, a third party's rights, applicable law, or the AI tool's own terms.

8. Model Governance

- **Default models.** Standard-tier frontier models are the default for confidential work, on the strongest retention configuration the current plan tier supports; zero-data-retention requires an enterprise or negotiated API arrangement (Section 6).
- **Extended-retention model classes.** Some frontier model classes carry a mandatory extended vendor safety retention (30 days at some vendors) that overrides shorter retention settings. The Approved AI Tool Register identifies them; they are isolated to a retention-acknowledged workspace and barred from customer content and crown-jewel material in all cases.
- **Retention reality.** Standard commercial API retention is short (about 7 days as of this writing; 30-day opt-in for audit; ZDR negotiable), but automated abuse-detection can retain flagged content longer even under ZDR. Contracts bound the normal case, not the flagged case: genuinely sensitive data stays inside managed boundaries regardless of contract.
- **Version pinning and change logging.** Model and tool versions are pinned and updated on a schedule; model changes in standing workflows are logged and material changes trigger regression checks.

9. Security Architecture for Code-Connected AI

Current state: approved coding tools may work with Magestic code under this harness, with a human in the loop on every change. No AI tool holds autonomous write, push, or deploy access to any repository or production system; agents propose, engineers review and apply. The five layers below are the mandatory operating conditions for every code-connected session, configured before the first one runs, not after an incident.

The reasoning the framework rests on: rules that live in people's heads fail under deadline pressure; controls that live in configuration hold regardless of who is typing. Models follow instructions probabilistically, and "almost always" is not a security property, especially against prompt injection hidden in content an agent reads. All five layers are native features of current tools; none is on by default.

Layer	Control	What it stops
1 · Read-only defaults	Analysis-only session modes (plan mode) as the committed per-repo default; agents propose diffs, humans apply them	Unwanted writes and destructive actions
2 · Deny-first rules	Tool denials (edit/write/push/delete), path denials (customer-data directories, .env and credential files, denied even for reading), command denials; deny beats allow in every mode; managed settings override user config	Prompt injection acting on the repo; data exfiltration via prompts; credential leakage
3 · Scoped workspaces	Sessions run on fresh, shallow clones in scratch directories, deleted afterward; per-repo grants stay narrow	Blast radius; cross-project exposure; persistence
4 · Zero standing credentials	Scratch environments hold no push tokens, deploy keys, or cloud credentials; platform	A compromised session reaching production

Layer	Control	What it stops
	token scopes enforce independently; same-day rotation of any exposed key	
5 · Audit logging	Structured telemetry (OpenTelemetry) for every session, tool call, file read, and command, routed somewhere durable; monthly anomaly review	Compliance and audit gaps; unanswerable questionnaires; incident forensics

Untrusted content. Everything an agent reads (repo files, tickets, web pages, third-party configs) is untrusted input. External content is inspected before an agent acts on it in a privileged context; instructions found inside data are never followed by policy; hooks provide deterministic pre/post-tool-call enforcement; the human review gate is the final backstop.

Supply chain. Pin and update tool versions on a schedule; treat foreign repo configs as executable input; lock behavior-altering environment variables on shared machines; vet every IDE extension, MCP server, and plugin as a dependency audit.

Endpoint access paths: grant the narrowest path that does the job. Ranked from narrowest to broadest: the web interface (reaches only what is typed or uploaded) for research and drafting; the IDE extension (reaches the open workspace only) for day-to-day coding; the CLI agent in a scratch directory (reaches one clone, under committed permissions) for deep analysis; CI or hosted agents (reach whatever the platform token allows) for automation; and desktop applications with broad file access, which are approved only where installation and scoping meet the endpoint rules below. Capability is not the trade-off: the narrower paths deliver the same models and the same quality; only the blast radius differs.

Endpoint security rules. No AI tool may be installed in a way that weakens a machine-wide security control. If an installer requires enabling developer or sideloading modes, trusting an unsigned package, or disabling an endpoint protection, the installation is declined and the tool is used through a narrower path (web, IDE extension, or CLI) instead; declining such an installer is always the right call on a machine that holds customer data, and the incident is logged so the Approved AI Tool Register reflects the restriction. When a vendor later fixes its installer, the tool is re-evaluated on scoping (what it can read and write), not packaging. This rule exists because it was tested in practice: an AI desktop application requesting a machine-wide developer-mode exception is a real security risk, and the policy answer is a standing rule, not a case-by-case debate.

This section states the security requirements; the implementation detail (committed permission configurations, hook scripts, CI token scopes, telemetry setup, and the hardening checklist) lives in the companion AI Security Architecture standard maintained by the Director of AI. The standard changes with tooling; this policy changes only when the requirements themselves change.

Gateway (future control). If and when AI traffic grows beyond chat-based productivity use, traffic routes through a self-hosted gateway providing DLP, secret scanning, PII redaction (the privacy filtering of Section 4.4), and prompt logging. The gateway is mandatory on any future pipeline carrying customer-derived data into a managed boundary.

10. Third-Party AI Within Magestic Products: Not at This Time

10.1 Current position

No Magestic product embeds, ships, or calls any third-party AI service or model at runtime: our software makes no connection to any AI service, so nothing a product touches, including customer data, ever flows from the product to one. This is a deliberate leadership position. Two distinctions keep it precise. First, the proprietary optimization engines inside our products are Magestic-built technology (Section 2), not third-party AI; they run entirely within the product, and nothing about them changes under this policy. Second, developers using AI tools to help write product code (Sections 7.3 and 9) is development tooling, not AI in the product: what ships is human-reviewed code that runs without any AI service behind it. What this section prohibits is a product capability that depends on a third-party AI model or service at runtime; no team may prototype, pilot, or ship one on the strength of this document.

This position also shapes the customer answer, stated precisely so every clause stays true: Magestic's products contain no third-party AI and make no connection to any AI service, so no data of any kind flows from our products to one; the optimization technology inside them is proprietary, built and controlled entirely by Magestic. Separately, in our internal operations, we use enterprise AI tools under no-training terms, with engineers reviewing everything that ships; identifiable customer data does not enter those tools, and verifiably de-identified customer material is used only where the governing contract permits it and a documented clearance exists (Sections 4.2 and 4.3). Stricter contract terms are honored in full. Every clause is verifiable from the Data Use Register and workspace configuration records.

10.2 What changing this would require

The position can change only by explicit decision, never by drift. Any future product capability that depends on a third-party AI model or service at runtime requires, in order: a Director of AI recommendation to the AI working group; C-suite approval; a revision of this policy issued before development begins; and then the reserved gates below, completed before anything reaches a customer:

- Documented risk assessment and review under the AI management system (Section 6), with human-oversight checkpoints and production monitoring.
- A managed boundary fit for purpose: in-tenancy cloud capacity with region pinning, per-customer isolation, privacy filtering, and no-training inference. Extended-retention model classes never sit on customer-content paths.
- An AI Feature Disclosure published for the capability: functionality, model source, data sources, customer choice (defaulting to opt-in for identifiable content), and safeguards. The disclosure framework is defined and reserved in this policy so it is ready if ever needed.
- Customer consent or written approval where any contract or compliance schedule requires it, confirmed engagement by engagement through the Data Use Register.

10.3 Vendor and model selection (internal tools)

For the internal tools Magestic does use, third-party models and AI vendors are evaluated for data-handling terms (retention, training, residency), security posture, reliability, and the intellectual-property

protections they offer (Section 11.2). Selection and material changes are approved by the AI working group and recorded in the Register.

11. Intellectual Property

Intellectual property is Magestic's core asset and a core risk. We manage IP in three directions: protecting what is ours, respecting what is others', and setting fair AI rules for users of our own products.

11.1 Protecting Magestic's proprietary IP

- **Trade secrets first.** The nesting engine, genetic-algorithm strategy, and no-fit-polygon methods are protected primarily as trade secrets: least-privilege access, segregation of proprietary code, NDAs, and IP-assignment clauses in all employment and contractor agreements. Trade-secret protection survives only if we take demonstrable steps to keep the material secret.
- **Patents where novel; copyright and registration.** Genuinely novel methods may be patented, coordinated with counsel before any public disclosure. Source code and written works are protected by copyright; key works are registered.
- **Preserve human authorship.** Purely AI-generated output may not be copyrightable in some jurisdictions, including the U.S. The flag-don't-fix workflow (Section 7.3) keeps a Magestic engineer as the author of every shipped change; material AI assistance is noted in commit or PR descriptions.
- **Never train others on our IP.** Proprietary code, algorithms, and confidential data are used only with AI tools under contractual no-training and no-retention terms, and never through extended-retention model classes.
- **Protect IP in delivery.** Crown-jewel logic ships compiled or server-side where feasible; customer agreements license the software, reserve all IP to Magestic, and restrict reverse engineering.

11.2 Respecting others' IP

- **Use vendors that indemnify, and meet the conditions of coverage.** Prefer enterprise AI services providing IP indemnification for generated output; enable and document the guardrails the indemnities require so coverage is not voided. Treat indemnities as a conditional backstop, not a guarantee.
- **Scan for provenance and license contamination.** AI-assisted code is scanned in CI for open-source and copyleft obligations before merging into proprietary code, and AI-introduced open-source components flow into each release's disclosure documentation and any contractually required open-source exhibits. This scanning is a standing condition of the human-in-the-loop rule in Section 7.3.
- **Keep training data clean.** Data used to train or fine-tune Magestic models must be properly licensed, owned, or within rights granted under Section 12. We do not train on scraped, pirated, or rights-encumbered material. (Models trained on datasets that are not exclusively licensed or risk-free create infringement exposure for their outputs. Magestic does not accept that trade.)

11.3 AI rules for users of Magestic products

For incorporation into Magestic's own terms with counsel:

- **Customers own their data and may train on it.** Customers may train machine learning or AI models on their own designs and data produced with Magestic products.
- **No replication of Magestic functionality.** Using Magestic offerings or their outputs to reverse engineer or replicate the functionality of any Magestic offering, including through training of any machine learning or AI model, is prohibited.
- **Scraping restrictions protect Magestic content, not customer content.** Automated collection restrictions apply to Magestic content and content Magestic licenses, and expressly not to the customer's own data.

12. Customer Content Rights Strategy

Established software vendors can use customer content to improve their offerings because their own terms of use obtain the rights that make it lawful: a customer license to use content in connection with providing and improving offerings, and a metrics framework that separates usage data from content itself. Some of Magestic's existing engagements are the mirror image: agreements drafted on the customer's paper can prohibit use of customer data even in aggregated or de-identified form. This section closes that structural gap for future contracts. With counsel, Magestic's standard agreements and terms will incorporate:

- **A limited content license:** the customer authorizes Magestic to use, reproduce, and modify customer content as needed to provide, maintain, secure, and improve the offerings, at the customer's request or with consent, and to meet legal obligations.
- **A metrics carve-out:** Magestic may collect and use information about usage, volume, type, and processing of content (but not the content itself) to operate and improve the business.
- **The choice framework:** where an AI feature would learn from customer content, the AI Feature Disclosure states the choice format, defaulting to opt-in for identifiable content.
- **An AI-use disclosure and acknowledgment clause:** a short clause for new MSAs, SOWs, and renewals disclosing Magestic's governed AI use and obtaining the customer's acknowledgment, turning this policy into a contractual shield.
- **The AI Use Rider:** the pre-drafted rider (with plan-tier variants) remains the starting paper for negotiated deals, so the next contract starts from Magestic's template rather than the customer's.

Until a given customer's contract includes these rights, that customer's data receives the default treatments of Section 4.2, and schedule-restricted engagements remain fully excluded.

13. Contract-Specific Compliance Schedules

Where an executed customer contract imposes obligations stricter than this policy, those obligations are implemented as a numbered schedule scoped to that engagement's data. Schedules are maintained by the Director of AI with counsel, and the contract check in Section 4.2 is the operational trigger. A schedule can only add restrictions for its engagement; it does not relax this policy for anyone else, and this policy does not relax any schedule.

How schedules work

Each schedule is a separate, confidential addendum to this policy, prepared by counsel from the executed contract. It identifies the engagement, cites the governing clauses, and states the operational rules in force for that engagement's data. Schedules are referenced in the Data Use Register, which is where personnel encounter them: the clearance check in Section 4.2 returns the schedule's restrictions before any data is touched. Schedules are not reproduced in this document, both because they contain customer-confidential terms and because the policy should not require reissue every time a contract is signed or amended.

Obligations a schedule may impose, each of which this policy is built to absorb without exception-making:

- Full exclusion of the engagement's data from AI systems in every form, including anonymized, de-identified, or aggregated.

- Residency and infrastructure requirements, such as processing exclusively in specified regions or on dedicated, non-shared hardware, with written approval required for anything else.
- Accelerated security-incident notice clocks, measured in hours rather than days, covering suspected as well as actual compromise, with the customer controlling external notifications.
- Certified return or destruction of all engagement data on demand or at termination within a fixed number of days, across all media including third-party providers' systems, with officer certification.
- Open-source disclosure, non-infringement warranty, and security-assessment obligations that reach AI-assisted code shipped in the product.
- Audit and inspection rights, insurance minimums, export-compliance warranties, extended confidentiality survival, and flow-down obligations to any third party Magestic answers for.

Where a schedule's obligations make a desired AI use impossible, the remedy is contract amendment negotiated by counsel (for example, a written-approval mechanism for named AI configurations), never quiet non-compliance. Until an amendment is executed, the schedule stands as written.

14. Regulatory and Standards Alignment

- **EU AI Act.** Deployer obligations (Article 26) and transparency duties (Article 50), with most obligations effective August 2026, are addressed through the AI-system inventory with per-use-case risk classification, human oversight, labeling of AI-generated content where required, and use of AI tools per vendor instructions. Staff AI-literacy expectations (Article 4) are addressed through policy training at rollout and refreshers at the quarterly review. Magestic's products contain no third-party AI, and their proprietary optimization engines are expected to classify as minimal risk; any future third-party AI feature shipped to EU customers would get a conformity check in the release process.
- **Data protection.** GDPR/UK GDPR, CCPA/CPRA and analogues: vendor DPAs with Article 28 terms; SCCs plus UK Addendum for transfers with transfer impact assessments; DPIA where AI processing of personal data is likely high-risk; records of processing updated with AI entries.
- **Export control.** ITAR/EAR treated as a first-class AI risk (Section 5.1): Tier 4 exclusion, classification gate, and counsel review of defense-adjacent holdings.
- **Frameworks.** NIST AI RMF (Govern, Map, Measure, Manage) structures the program; ISO/IEC 42001 defines its shape (Section 6).

15. Incident Response and Enforcement

Reporting. Suspected policy violations, data exposure, IP concerns, or AI incidents (harmful, biased, or infringing output; a file that should not have been read; a key that appeared in a prompt) must be reported the same day to the Director of AI or through Magestic's incident channel.

Playbook. (1) Contain: stop the workflow; revoke the session, token, or seat. (2) Assess: what data class was exposed, to which vendor, under which terms; tier matters more than volume. (3) Invoke vendor process: commercial tiers have deletion mechanisms, and short retention windows favor a fast response. (4) Rotate and log: any credential involved is rotated same-day; the event, cause, and fix enter the exception log. (5) Escalate: if Tier 4 is possibly involved, counsel immediately; export-control regimes have voluntary-disclosure procedures where speed materially matters.

Contract clocks. Where an incident touches an engagement with a compliance schedule, that schedule's notice obligations apply; some schedules require written and email notice within hours, cover suspected as well as actual compromise, and give the customer control of external notifications. The IR plan nests vendor DPA notice duties and, for personal data, the GDPR 72-hour authority clock inside the response timeline.

Enforcement. Violations may result in revocation of AI tool access and disciplinary action up to and including termination, and may carry legal consequences. Enforcement is proportionate and consistent.

16. Review and Maintenance

This policy is reviewed at least quarterly, and sooner upon material changes in law, AI tooling, vendor terms, customer contracts, or Magestic's products. Revisions are prepared by the Director of AI in conjunction with the AI working group and signed at C-suite level. The quarterly review re-certifies the approved-tool list, reviews the exception log and seat assignments, refreshes version pins, verifies vendor paperwork, and reviews the compliance schedules against contract changes.

Version	Date	Summary
1.0	July 2026	Initial policy: Trusted AI principles, managed-boundary data governance, customer-data clearance protocol and Data Use Register, AI feature disclosures and choice framework, model governance, five-layer security architecture, IP protection, customer content rights strategy, contract-specific compliance schedules.

17. Definitions

Term	Definition
AI	Systems that learn from data or search large solution spaces to produce outputs, recommendations, or decisions, including ML, generative AI, LLMs, agentic tools, and optimization algorithms.
Managed boundary	An AI processing environment Magestic controls: in-tenancy hosted models or company-managed business-tier and commercial API endpoints under no-training terms, with retention minimized and feedback sharing disabled (Section 4.1).
No-public-training commitment	The standing commitment that data processed through Magestic-managed AI infrastructure is never used by external model providers to train their public models.
AI Feature Disclosure	Magestic's per-feature transparency card (functionality, model source, data sources, customer choice, safeguards), defined and reserved in Section 10.2 for any future, leadership-approved product AI.
Choice format	The disclosed customer control for a feature: Opt-in, Opt-out, No (no choice offered), or N/A (no customer content used).
Compliance schedule	A numbered addendum to this policy implementing an executed contract's stricter obligations, scoped to that engagement's data (Section 13).
Company AI account	An account provisioned by Magestic inside a company workspace under commercial or business terms with an executed data processing agreement, centrally administered and billed directly to Magestic. The only kind of account permitted for Magestic work.
Personal AI account	Any AI account not owned and administered by Magestic: free, trial, consumer, or individually-subscribed accounts belonging to a person, at any price, whether or not the cost is expensed or reimbursed. Prohibited for all Magestic work (Section 7.1).
Customer data	Data and content a customer provides or that arises from work for the customer, as defined in the applicable contract. Customer definitions often sweep broadly, covering configurations, pricing, financial information, supplier and customer lists, and PII, in addition to technical files.
Data Use Register	The per-engagement record of clearances under Section 4.3: documents reviewed, clause citations, regulatory position, approved anonymization method, permitted treatments, approver, counsel sign-off where escalation applied, and review date.
Anonymization / de-identification / pseudonymization	Anonymized data cannot be re-identified by means reasonably likely to be used (GDPR Recital 26 standard). De-identified data (CCPA/CPRA) requires safeguards and a commitment not to re-identify. Pseudonymized data remains personal data under GDPR. Only verified anonymization under Section 4.3, step 3 qualifies for the Section 4.2 treatments.

Term	Definition
Extended-retention model class	A model class whose vendor terms impose a mandatory extended safety retention that overrides shorter retention settings; identified in the Approved AI Tool Register and isolated per Section 8.
ZDR	Zero data retention: vendor terms under which inputs and outputs are not stored at rest after the response returns. Abuse-detection carve-outs can override retention terms for flagged content.
Deemed export	Release of export-controlled technical data to a foreign national, even inside the U.S., including via vendor personnel access to processing systems.
Human in the loop (flag, don't merge)	The working rule that AI may analyze, draft, and write, while a Magestic engineer reviews, tests, and merges every change that ships, owning it as their own work.
Trade secret	Confidential business information that derives value from secrecy and is protected by reasonable secrecy measures.

Appendix A: Approved AI Tools and Configurations

Maintained by the Director of AI and re-certified quarterly. A tool is approved only in the configuration listed; the same product on a personal account or default settings is not approved.

Tool category	Approved use	Required configuration / status
In-IDE coding assistant	In-editor assistance for developers, including drafting product code	Business tier; no training on business data; workspace-scoped; company account only. Human review and testing before every merge (Section 7.3).
CLI coding agent	Whole-repo analysis, automated read-only testing, scripted/CI use, agentic development on Magestic-owned code	Team-tier or commercial API account; per-repo committed settings (read-only default, deny rules); scratch-clone workspaces; standard-tier frontier models; no autonomous push or deploy access; human review before every merge. Adopt under the Section 9 harness.
Research and chat assistant	General research, drafting, second opinions, cited answers	Business tier; no training on inputs; admin controls; feedback sharing disabled. Adopt.
AI-native IDE	Interactive spot-checks and refactoring	Team tier or above; privacy mode enabled and locked org-wide; per-repo exclusion files; Section 9 harness applies. Evaluate.
Meeting transcription and summarization	Internal meetings with participant awareness; customer calls only with consent (Section 7.4)	Company-managed seats; org admin settings reviewed; tenant-bound options preferred for customer-facing calls. Adopt per procurement.
Desktop AI applications with broad file access	Document and file automation for non-developers	On hold on any endpoint where installation requires weakening machine-wide security controls; editor- and CLI-based access paths cover the gap. Hold.
CI review bot	Automated pull-request review	Comment-only permissions; zero push access; API key in the platform secret store; pinned version. Phase 2, under the Section 9 harness.
In-tenancy model hosting	Reserved: the defined path for any future customer-content or product AI processing (Sections 4, 10)	Not deployed. Would require leadership approval, Magestic cloud tenancy with region pinning and customer-managed keys, a gateway in front, and customer approval where a schedule requires it.

This appendix is deliberately vendor- and model-agnostic. The specific products, models, versions, and account tiers approved within each category are named in the Approved AI Tool Register, maintained by the Director of AI, re-certified quarterly, and updated without amending this policy. A product is approved only in its registered configuration; the same product on a personal account or default settings is not approved.

Appendix B: Prompt Do's and Don'ts

Do	Don't
Use approved, no-training tools on company-provisioned, company-paid accounts	Use a personal AI account of any kind for any Magestic work, even if expensed or reimbursed
Confirm a Data Use Register clearance exists before any customer-derived data, even anonymized, touches an AI tool (schedule-restricted engagement data never enters AI in any form)	Assume every customer's contract allows what this policy's defaults allow, or that anonymization by itself is authorization
Anonymize or substitute synthetic data before AI contact with customer material	Paste identifiable customer CAD files, geometry, PLM/CRM records, or order data into any tool outside a managed boundary
Keep export-suspect material away from AI entirely	Assume anonymization fixes an ITAR/EAR problem; Tier 4 has no anonymization exception
Treat AI output as a draft; review, then author your own change	Ship or commit AI output without human review, or let an agent modify production code
Scan AI-assisted code for license and security issues before merge	Merge AI code blindly into proprietary repositories
Use standard-tier frontier models for confidential work	Put customer content or crown-jewel material through extended-retention model classes (mandatory extended vendor retention)
Keep secrets in vaults; deny credential paths from agent reads	Let an API key, credential, or .env file appear in a prompt; if it happens, rotate same-day and log it
Ask the AI working group when unsure; log the answer	Assume a new tool, model, or use case is approved

Appendix C: AI Risk Classification Matrix

Tier	Description	Controls
Low	Internal productivity on T1-T2 data	Approved tool plus approved configuration; human review of anything leaving the company.
Medium	Customer-facing output drafted with AI (no identifiable customer inputs), cleared anonymized T3 workflows, or internal use touching crown-jewel T2 material	Documented human review, logging, data-class checks, Register clearance and verified anonymization, model governance (no extended-retention model classes for sensitive material).
High	Raw customer content inside a managed boundary, training or fine-tuning on customer-derived data, safety-relevant or regulated decisions, any future third-party AI in a product	Leadership authorization and a policy revision where Sections 9-10 require it, AI management system review, disclosures, customer consent where required,

Tier	Description	Controls
		monitoring, contract/IP review. Raw customer content currently has no route (in-tenancy not deployed).
Prohibited	Third-party AI embedded in or called at runtime by any Magestic product (Section 10); AI-drafted code merged or deployed without human review, or any AI tool with autonomous write/push/deploy access (Section 9); schedule-restricted engagement data in any AI system in any form; Tier 4 data in any AI tool; customer data in consumer tools	Not permitted at this time. Report any occurrence as an incident (Section 15).

Appendix D: How This Policy Answers Key Leadership Questions

Question	Where it is addressed
What best practices protect the company when using AI?	Sections 3-9 (principles, managed boundary, classification, governance, acceptable use, model governance, security architecture); Appendices A-C.
Does this follow recognized industry practice?	Yes, by design: Section 4 (managed boundary, no-public-training commitment, isolation and privacy filtering), Section 10 (a clear no-product-AI position with a reserved disclosure framework), Section 6 (ISO 42001-shaped management system), and Sections 11.3 and 12 (acceptable-use and content-rights patterns drawn from leading vendors' published terms).
How can other software vendors use customer data with AI when some of our contracts forbid it?	Because their own terms take a license to use customer content to provide and improve offerings, while contracts drafted on a customer's paper can prohibit use even in de-identified form. Section 12 closes that gap for future Magestic contracts; compliance schedules keep restricted engagements excluded meanwhile.
Is our AI use consistent with our executed customer contracts?	Yes: the clearance protocol (Section 4.3) checks every engagement's contract before any data is touched, and compliance schedules (Section 13) implement stricter contracts in full, up to complete AI exclusion with accelerated incident and destruction clocks.
How do we protect our own proprietary IP, and avoid infringing others'?	Section 11.1 (trade secrets, human authorship, no-training terms, protected delivery); Section 11.2 (indemnifying vendors, coverage conditions, contamination scanning, clean training data); Section 8 (model isolation).
What do we tell customers who ask about our AI use?	Section 10.1: our products contain no third-party AI and make no connection to any AI service, so no data flows from our products to one; the optimization technology inside them is proprietary Magestic engineering. Separately, our internal operations use enterprise AI under no-training terms, with engineers reviewing everything that ships; identifiable customer data does not enter those tools, and verifiably de-identified material only with a documented, contract-checked clearance (Section 4.3). Stricter contract terms are honored in full; the disclosure framework (Section 10.2) stands ready if runtime product AI is ever approved.
Should every technology company have an internal AI policy?	Yes: leading technology and design-software vendors operate formal, certified AI governance programs; enterprise customers and regulators increasingly require it, and AI addenda and questionnaires are now table stakes.